
HARDEN WINDOWS AD - Projet



Contents

Mission : Durcir la machine Active Directory donnée par le formateur.	2
Description de la VM	2
CONTENTS	2
PRIVILEGED ACCESS	2
OBJECTIVE	3
TOOLING	3
GETTING STARTED	3
Les scripts :	3
Les tâches	4
Lien pour le rendu	4

Mission : Durcir la machine Active Directory donnée par le formateur.

Description de la VM

- Cette machine virtuelle (VM) contient une forêt Active Directory à domaine unique pour une organisation mondiale fictive, Corp Inc.
- Nom de domaine : corp.local Contrôleur de domaine : DC (Windows Server 2019)
- IP : 192.168.1.10
- Lien vers la machine : <https://www.swisstransfer.com/d/e03aa333-1074-469c-b5ed-f19c91b58246>
- Login de base : Administrator
- Mot de passe : Espoir15!

CONTENTS

1. plus de 200 unités organisationnelles réparties dans le monde entier
2. Plus de 1000 comptes d'utilisateurs de domaine pour tous les cadres de l'organisation, les employés, les sous-traitants et le personnel informatique.
3. Plus de 1000 comptes d'ordinateur de domaine, un pour chaque ordinateur portable/poste de travail d'un employé, ainsi que pour de nombreux serveurs dans plusieurs centres de données.
4. Plus de 200 groupes de sécurité de domaine utilisés pour déléguer l'accès administratif/privilégié dans AD et pour contrôler l'accès aux ressources à l'échelle du domaine.
5. Plus de 10 stratégies de groupe, 7 comptes de service non gérés et 5 comptes de service gérés, 4 points de connexion de service, 3 imprimantes publiées et 10 contacts.

PRIVILEGED ACCESS

L'accès privilégié pour divers besoins organisationnels (par exemple, la gestion de l'identité et de l'accès) a été délégué dans ce domaine fictif.

Pour ce faire, des autorisations de sécurité pertinentes ont été accordées à divers groupes de sécurité dans l'ensemble de la hiérarchie de l'OU.

Il existe plus de 150 000 autorisations de sécurité Active Directory explicites, héritées, autorisées et refusées, spécifiées sur plus de 3 000 objets à l'échelle du domaine.

La plupart des groupes auxquels l'accès a été délégué dans AD résident dans l'OU "IT Security Groups" au sein de l'OU "IT" dans l'OU "San Francisco"

Les comptes de la plupart du personnel informatique et des utilisateurs privilégiés membres de ces groupes se trouvent dans l'OU "IT Personnel" de l'OU "IT".

OBJECTIVE

L'objectif principal de cette VM est d'aider chacun à apprendre comment auditer "correctement" les accès privilégiés dans un déploiement Active Directory.

TOOLING

2 outils (voir la barre des tâches ci-dessous) ont été prévus pour vous - "Active Directory Users and Computers" (Utilisateurs et ordinateurs du répertoire actif).

Pour comparer les résultats de l'audit/analyse, vous pouvez également installer tout autre outil d'audit des utilisateurs/accès privilégiés d'Active Directory de votre choix.

GETTING STARTED

Pour vous familiariser avec ce domaine AD fictif, commencez par lancer "Active Directory Users and Computers" à partir de la barre des tâches ci-dessous.

Remarque : l'utilisation de cette VM ne nécessite PAS de connexion à Internet ; si vous souhaitez vous connecter, veuillez sécuriser cette VM au préalable.

Les scripts :

Sur le bureau il y a un dossier script avec les scripts suivant qui pourrait vous aider :

- delegations.ps1 : Affiche toutes les délégations présentes de l'AD
- acl.ps1 : Voir quel objet a des droits sur quel objets (modifier le DN dans le script pour mieux cibler)
- ouperm.ps1 : Ce script vérifie les autorisations d'accès sur les OU spécifiées, ce qui permet de comprendre qui a accès à quoi dans la structure de l'Active Directory (modifier le DN dans le script pour mieux cibler)
- securitygroups.ps1 : Affiche les membres des groupes de sécurités dans une OU
- auditgpo.ps1 : Audit les GPO
- Un backup est présent dans C : \Backup au cas ou

Les tâches

- Tenter la génération de golden ticket avec mimikats en suivant la documentation
- Auditer l'active directory et plus particulièrement l'OU "North America" et répertorier :
 - Les comptes/groupes à fort privilèges
 - Les délégations
 - Et tout autres groupes à privilèges particulier
 - En faire un bref tableau récapitulatif des différentes
 - Les GPO et leur fonctions
- Mettre en place un modèle de tiering au choix pour "North America" et réorganiser les objets dans ce modèle.
 - Restreindre les connexion qui ne sont pas dans leur tier
 - Mettre en place une OU d'administration
 - Ajouter des GPO de mitigation des attaques communes comme celles sur le NTLM ou le LLMNR, mimikatz etc...
 - Autoriser les connexion RDP pour le tier 0 mais pas pour les autres
 - Vous pouvez le mettre en place pour les autres OU si vous le souhaitez.
- Avoir un score de 0 sur PingCastle.
- Déployer un PAW avec les droits nécessaires pour l'administration du DC
 - Aide avec le modèle classique ([PAW Security guide – Identity and Azure Cloud \(azure-blog.pl\)](#))
 - Tips : Essayer de coucher sur papier en avance les règles associés à ce PAW (eg: RDP autorisé, login via un certain tier etc..) puis y associer vos GPO
 - Le but est d'appliquer des restriction de Login et d'avoir un computer accessible en RDP uniquement avec un compte d'admin du tier0
 - La machine PAW pourra ensuite accéder à des machines du tier1 (server) et tier2 (windows10)
- Vous pouvez tenter un scan de vulnérabilités ou un autre outil d'audit.
- Réessayer la génération de golden ticket après toutes vos actions.

Aide pour la mise en place du modèle classique : [AD Tiering model – how to deploy that – Identity and Azure Cloud \(azureblog.pl\)](#)

Modèle HardenAD : [GitHub - LoicVeirman/HardenAD: Hardening Active Directory version 2](#)

Lien pour le rendu

- Rendre au format PDF : NOM_PRENOM . pdf

- Date de rendu : 16/07/2025
- Lien de rendu : LE MEME QUE CELUI POUR LINUX AVEC LES MÊMES CONDITIONS